

Recette fonctionnelle CRM

Audit avant mise en production · 24 septembre 2026

Cartographie 100% du code + **18 tests réels** sur la base de production (compte commercial jetable, webhook, base de données), avec nettoyage systématique. Rien de fabriqué. Légende : **OK** testé OK · **BUG** bug confirmé · **FIX** à corriger (code) · N/T non testable ici. Supersede l'ancienne recette (A03/A04/A05/A10/A11/A12 corrigés).

Synthèse

CRM riche et globalement fonctionnel, mais **5 bloquants P1** à corriger avant prod, plus des écarts sur le chemin **OPTIMIVV** (secteurs nettoyage + déménagement, le cœur du business).

Bloquants P1 (avant prod)

#	Bloquant	Preuve
1	Fuite devis_optimivv + factures : tout commercial lit noms/emails/montants de tous les clients	BUG testé (5/15 lus) — RLS using(true)
2	Fuite cert_hotte (données personnelles clients)	BUG testé
3	Page /documents sans garde de rôle (lecture service-role non scopée -> contourne la RLS)	BUG code confirmé
4	audit_logs perdu pour webhooks/signatures publiques -> conformité + moteur d'actions aveugle	BUG testé (lead webhook = 0 audit)
5	Signature OPTIMIVV faible : jeton rejouable, signe le dernier devis, sans expiration	BUG code (exploit non exécuté)

Importants P2

- **BUG** Auto-escalade is_premium/is_extreme par un commercial (testé).
- **BUG** Double dossier par lead : aucune contrainte UNIQUE(dossiers.lead_id) -> la lecture .maybeSingle() casse ensuite (testé).
- **BUG** OPTIMIVV signé avec acompte sans facture d'acompte (testé, 2 cas réels).
- **FIX** KPI dashboard : date TODAY figée au boot, mediane = min-max, conversionRate bases mixtes, funnel EUR fabriqué, CA /performance != /dashboard.
- **FIX** CA fiche Client en TTC vs Comptabilité en HT · monotonie pipeline partielle (A06) · marquage signé manuel sans preuve (A08) · numérotation CTR-/CERT- hors transaction · statut retard jamais posé · drag Kanban->signé OPTIMIVV ne crée pas de dossier.

Mineurs P3

Refus découverte via window.prompt sans confirmation · callLead code mort · secret cron en query-string · défauts OPTIMIVV codés en dur · liens nav 403 affichés à tous · double-fire WF2 · appariement Brevo au dernier lead · ouvert prématuré (préchargement pixel).

Vérifiés OK (test réel)

OK Tenancy leads mine · idempotence webhook · notif différenciée admin/commercial (provenance admin only) · RLS contrats scopée · **INSERT contrat client d'autrui bloqué** (le flag S3 était un faux positif) · audit admin-only · chiffrement provenance · calculs Système A (remise/HT, TVA par ligne, recalcul serveur). **Signature du système principal robuste** : attribution 1:1, PDF figé + SHA-256, aucun croisement A/B/C.

Constat structurant

Deux moteurs parallèles (Devis A documents/TVA vs B **OPTIMIVV** ; signature principale robuste vs **OPTIMIVV** faible). **Le point faible est systématiquement OPTIMIVV — qui sert les secteurs principaux.**

Parcours (statut global)

Commercial **FIX** · Planificatrice **FIX** · Client **FIX** (e-sign principal **OK** / OPTIMIVV **BUG**) · Super Admin **FIX**.

Non testable ici

N/T Click-through UI complet · e-sign prestataire live · livraison email/SMS réelle · runs n8n WF1/WF2 live · responsive mobile/tablette · MFA. (Marqués avec raison, jamais OK sur le seul code.)

Ordre de correction recommandé

- 1 **Avant prod** : P1 1-2-3-4 (sécurité/conformité).
- 2 Chemin argent OPTIMIVV : P1-5, facture d'acompte, double dossier, Kanban->signé.

- 3 Fiabilité des chiffres : KPI + CA.
- 4 Hygiène : P2/P3 restants.

Aucun code modifié (phase audit). Correctifs = phase 2 sur autorisation.